WINDOWS SYSTEM HARDENING PROJECT

Based on CIA Triad Principles

Prepared by: Muhammad Afaq Abbas

Date: 13/02/2026

Platform: Windows 11

Confidentiality	Integrity	Availability
Protect sensitive information from unauthorized access	Prevent unauthorized changes to data and systems	Ensure systems and data are accessible when required

CONFIDENTIAL — SECURITY ASSESSMENT REPORT

1. Introduction

Windows Hardening is about making the Operating Systems more secure against potential attackers by reducing the number of possible ways to compromise or exploit them, and by minimizing the surface area of the OS that can potentially be attacked. This is achieved by configuring Security settings to appropriately protect them from potential threats to the Operating System.

This project was conducted on a Windows 11 system with the aim of improving its security posture through the implementation of practical security controls based upon the CIA Triad principles:

- Confidentiality - this is to protect sensitive information from unauthorized access.
- Integrity - this is to stop unauthorized change to data and/or systems.
- Availability - this is to ensure that systems and data are available to an Organisation when they are required.

The main objective of this project is to assess the baseline security condition of systems, implement hardening, and measure the difference in the level of improvements.

2. Initial Risk Assessment (Before Hardening)

Upon the complete initial assessment, the following security weaknesses were identified:

- Weak password policy
- Firewall not completely configured
- BitLocker encryption not enabled
- Unneeded services running
- Pending Windows updates
- No verified backup configuration

Identified Risks:

- Unauthorized access to the systems
- Has the potential for malware infection
- Increased potential for theft of customer data
- Utilization of known security vulnerabilities
- Have the potential to create an unstable system and result in data loss.

Before Hardening — Evidence Screenshots

Weak Password Policy (Before)

Policy	Security Setting
Enforce password history	0 passwords remembered
Maximum password age	42 days
Minimum password age	20 days
Minimum password length	8 characters
Minimum password length audit	Not Defined
Password must meet complexity requirements	Enabled
Relax minimum password length limits	Disabled
Store passwords using reversible encryption	Disabled

Figure B1: Password policy before hardening — no history enforcement, 8-character minimum, complexity disabled.

Firewall Disabled on All Networks (Before)

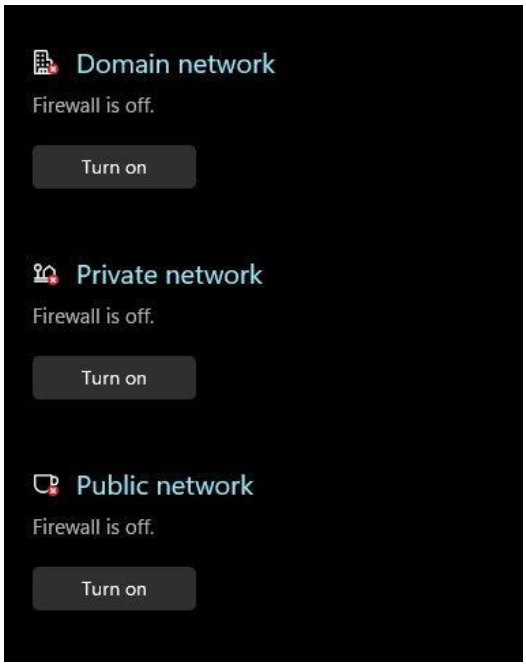

Figure B2: Windows Defender Firewall turned off on Domain, Private, and Public networks.

Windows Defender Protections Disabled (Before)

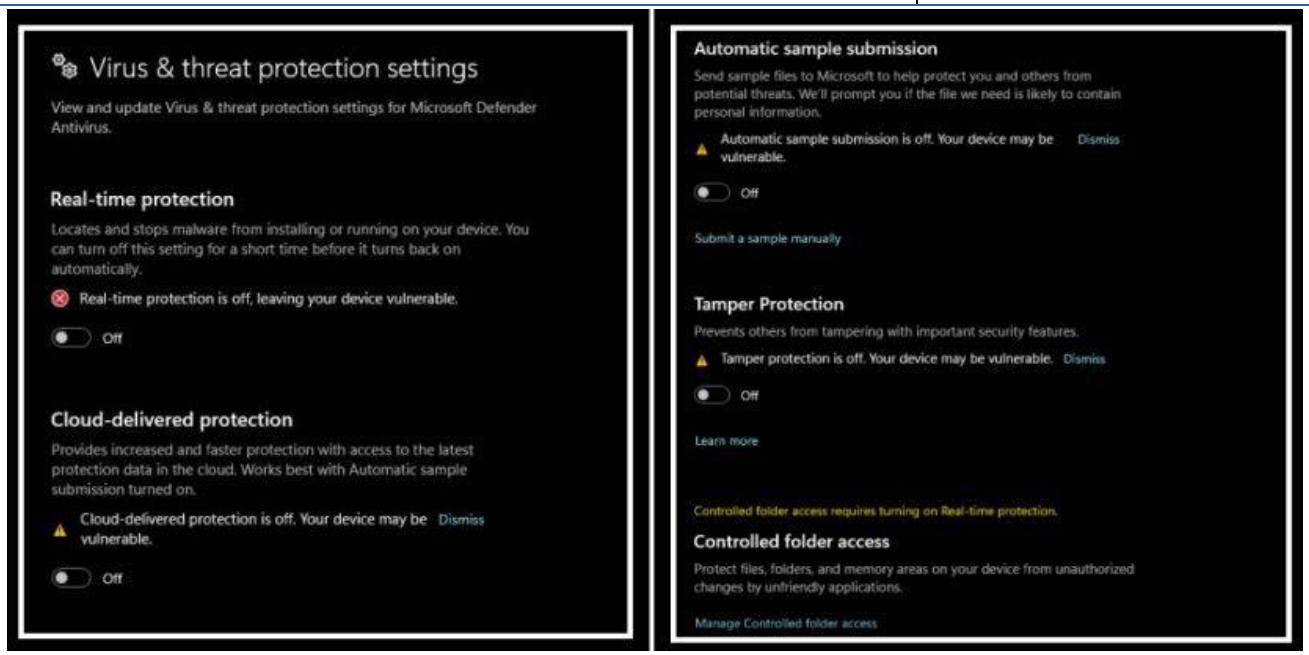

Figure B3: Real-time protection, cloud-delivered protection, automatic sample submission, and tamper protection all disabled.

BitLocker Encryption Not Enabled (Before)

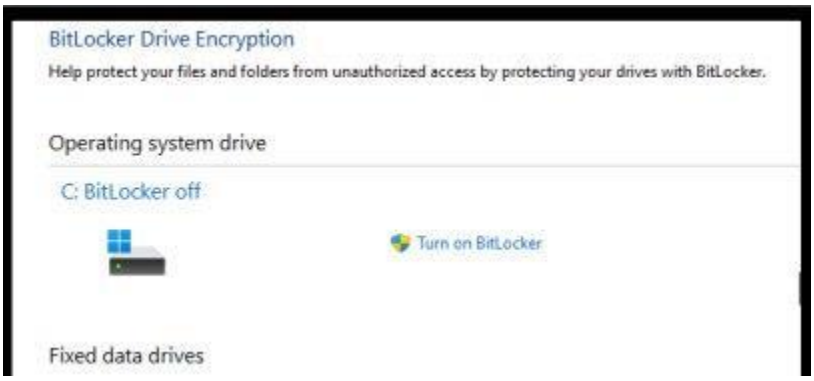

Figure B4: BitLocker Drive Encryption off — system drive unprotected.

No Backup Configuration (Before)

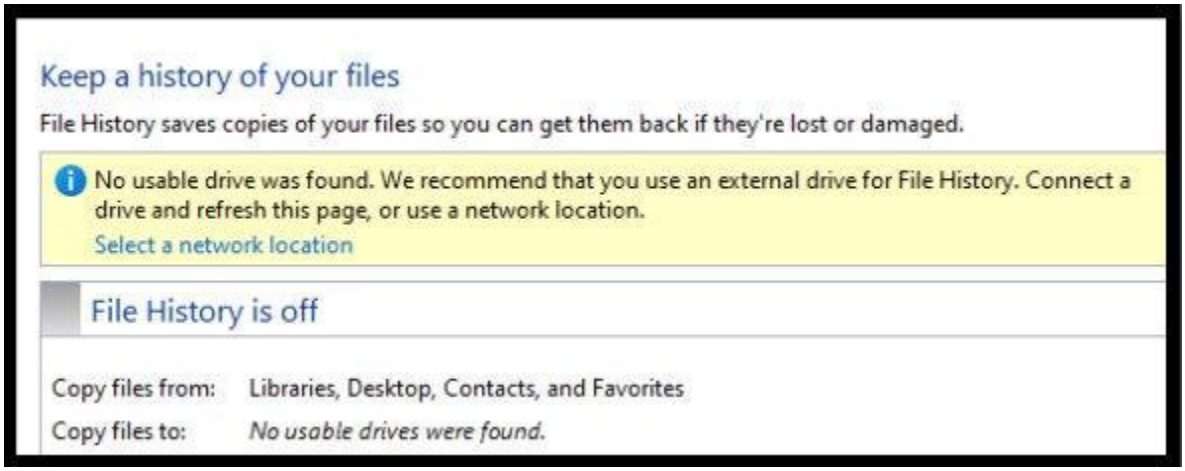

Figure B5: File History is off — no usable backup drives found.

3. Security Controls Implemented

Control 1: Enabled BitLocker Drive Encryption

CIA Principle: Confidentiality

The system drive has been encrypted with BitLocker Drive Encryption to protect confidential data from unauthorized access by an unauthorized individual who has physically obtained access to the drive.

Figure 1: BitLocker Drive Encryption activated to protect system drive data.

⚠ **Risk Mitigated:** Loss of data through theft or unauthorized physical access.

Control 2: Configured Strong Password Policy

CIA Principle: Confidentiality

Using the Local Security Policy (secpol.msc), the following password policy was implemented:

- Minimum Password Length: 12 characters
- Password Complexity Requirements: Enabled
- Password History Enforcement (Last 6 Passwords): Enabled.

Figure 2: Password Policy configured with a minimum of 12 characters and complexity enabled.

⚠ **Risk Mitigated:** Credential compromise and brute force attacks.

Control 3: Windows Defender Firewall has been Activated and Set Correctly

CIA Principle: Integrity

Windows Defender Firewall has been enabled on both private and public networks.

To protect from unauthorized access and exploitation of a network, I have implemented a custom inbound rule for the Telnet protocol (Port 23).

Inbound Rules

Name	Group	Profile	Enabled	Action	Override	Program	Local Address	Remote
Block Telnet Port 23		All	Yes	Block	No	Any	Any	Any

Figure 3: Windows Defender Firewall enabled with custom rule blocking Port 23 (Telnet).

⚠ **Risk Mitigated:** Unauthorized Remote Access and Exploiting of the Network.

Control 4: Windows Defender Protection Has Been Activated

CIA Principle: Integrity

The following Windows Defender protections were enabled:

- Real-Time Protection
- Cloud-delivered Protection
- Tamper Protection.

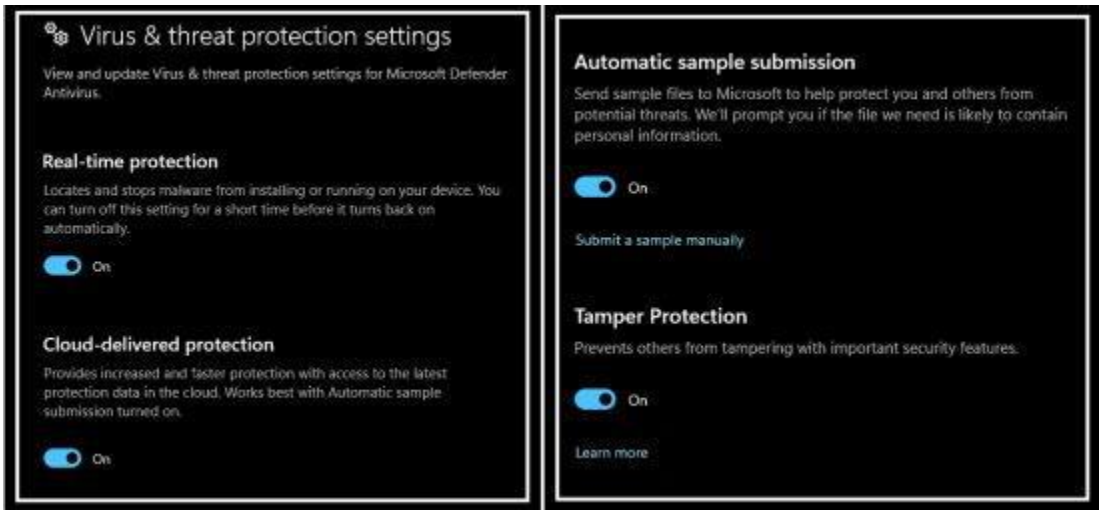

Figure 4: Windows Defender security protections activated.

⚠ **Risk Mitigated:** Change to Existing System Resources and Infection of Malware.

Control 5: Updated Windows Operating System

CIA Principle: Integrity

The complete set of installed updates is current according to Microsoft to patch defects and increase reliability.

Figure 5: Windows operating system updated with latest security patches.

⚠ **Risk Mitigated:** Exploitation of software defects.

Control 6: Disabled Unnecessary Services

CIA Principle: Availability

To help reduce the attack surface area and to increase performance, services that are not used (Remote Registry) have been turned off.

[Figure 6: Unnecessary service (Remote Registry) disabled.]

⚠ **Risk Mitigated:** Lessened exposure to attack and improved system reliability.

Control 7: Established Backup Strategy

CIA Principle: Availability

System Restore Points (Create Restore Point) and Backup of Files (Backup Files) have been created to ensure that in the event of a successful Ransomware Attack or system failure, all data can be restored.

Figure 7: File History backup enabled for automatic file protection.

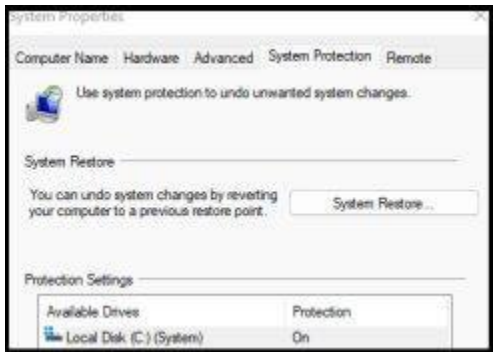

Figure 8: System Protection enabled for Local Disk (C:).

⚠ **Risk Mitigated:** Data loss and extended downtime.

4. Conclusion

This project demonstrates how a Windows 11 system can be significantly hardened against real-world threats through a structured, CIA Triad-based approach. Before hardening, the system was left exposed — the firewall was completely off, Windows Defender protections were disabled, BitLocker was not enabled, password policies were weak, and no backup strategy was in place. Each of these weaknesses represented a direct pathway for an attacker to compromise the system.

After implementing all seven security controls, the attack surface has been substantially reduced. Sensitive data is now encrypted at rest with BitLocker, strong password policies prevent easy credential attacks, the firewall blocks unauthorized traffic including legacy protocols like Telnet, Windows Defender actively monitors and defends the system in real time, the OS is fully patched against known vulnerabilities, unnecessary services are eliminated, and a backup strategy ensures recovery is possible even after a worst-case incident such as ransomware.

CIA Principle	Controls Applied	Outcome
Confidentiality	BitLocker + Password Policy	Data encrypted at rest; accounts protected from brute force
Integrity	Firewall + Windows Defender + OS Updates	Active threat detection, network filtering, and patched vulnerabilities
Availability	Disabled Services + Backup Strategy	Reduced attack surface and guaranteed recovery path

In summary, Windows hardening is not a one-time task but a continuous security practice. The controls implemented in this project form a strong baseline defence. Maintaining this posture requires regular patch management, periodic policy reviews, and ongoing monitoring — ensuring the system remains resilient against both current and emerging threats.

End of Report

Muhammad Afaq Abbas | 13/02/2026